UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 0 slot(s). Supported theory: 24 slots. Placeholders: 0. Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 15 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 0 computed, 24 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two characteristics of Trojan horse malware, including how it presents itself to users and what it does once active on a host.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojans disguise themselves as useful or benign software so users install them willingly.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.00 LOW	supported
2	Once running, a Trojan steals private data, deletes files, records keystrokes, or opens a way for additional malware.	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.57	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six techniques by which malware attacks and propagates, covering how virus code is attached to or substituted for a program's entry point, how early viruses spread through boot sectors, and how a worm used a mail service flaw to spread across a network.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A virus can be attached by appending the virus body onto an existing program file.	"Append a virus body to a program"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.44 LOW	supported
2	The virus saves the program's original entry point inside the virus body before taking control.	"Save an entry point to a program in a virus body"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.55	supported (ste gate)
3	The program's entry point is replaced with a jump into the virus body so the virus runs first.	"Replace a program entry point with a jump to a virus body"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.70	supported (ste gate)
4	After running, the virus code restores the	"Virus code restores the original entry point and jumps to it after its	051 - Software Security, slide 9	051 - Software Security::s09::1	0.64	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	original entry point and then jumps to it so the host program still executes.	own execution"				
5	Early malware such as Elk Cloner propagated by infecting the boot sector.	"A program spread via boot sector infection"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.33 LOW	partly supporte
6	The Morris worm spread by exploiting a debugging feature of sendmail that allowed remote execution.	"Used a debugging feature of sendmail (remote execution)"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.44 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 7; 051 - Software Security, slide 9

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the two stages of the biometric authentication process and state what activities occur within each stage.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The identification stage involves acquiring the biometric sample, creating the master characteristics and storing those master characteristics.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.33 LOW	supported
2	The authentication stage involves further acquisition(s), comparison of the presented sample and a decision.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A2b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Biometric technologies are increasingly deployed as an alternative to passwords. Explain the categories of biometric applications and the characteristics and drawbacks of the specific biometric technologies discussed in the course.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	State the definition of a biometric as a physiological or behavioural characteristic that can distinguish one person from another and can be used for identification or verification.	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.90	supported (ste gate)
2	Identify the two sectors into which biometric applications are categorised today.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.83	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

3	List the physiological biometric technologies: iris, fingerprints, hand, retinal and face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
4	List the behavioural biometric technologies: voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
5	Explain that iris scanning reads the unique pattern of the iris, needs no touch, and overcomes the issues of retinal scanners.	"Scans unique pattern of iris"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1	0.36 LOW	partly supporte
6	Give the disadvantages of fingerprint biometrics, including racial issues, dirt and wounds, finger placement, large database processing and spoofing, so liveness checking is important.	"Can be spoofed - liveness important!"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.18 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) key security models listed under formal security models in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Bell-La Padula (BLP) model, described as an access control only model.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	1.00	supported (ste gate)
2	The Chinese Wall model, described as identification of conflicts of interest.	"Chinese Wall model: identification of conflicts of interest"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 5

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the access control structures used to implement access policies, covering the access control matrix, access control lists and capabilities, and state the requirements such structures must satisfy.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Identify the access control matrix as one of the structures for implementing access policies.	"Access control structures are mechanisms for implementing access policies:"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.83	supported (ste gate)
2	State that capabilities are listed as a structure (C-List) alongside the	"Capabilities (C-List)"	023 - Access Control and Authorization,	023 - Access Control and Authorization::s0	0.20 LOW	supported

© Hak Cipta Universiti Teknologi MARA

	ACM and ACL.		slide 7	7::1		
3	Explain that an ACL is an object-centred description of access rights.	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.83	supported (ste gate)
4	Give one advantage of ACLs: easy access to the access rights of an object.	"easy access to object access rights"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.67	supported (ste gate)
5	Give one disadvantage of ACLs: difficulty of revocation.	"difficulty of revocation"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.25 LOW	supported
6	State that the ACM is a basic control structure offering clarity of definition and easy verification.	"ACM is a basic control structure."	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.44 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 7; 023 - Access Control and Authorization, slide 8

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a buffer overflow arises in a program such as the one using strcpy() into a fixed-size local buffer, and state what an attacker can achieve by exploiting it.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The overflow occurs because strcpy() copies the input without checking its length against the size of the destination buffer.	"strcpy() do not check the string length"	051 - Software Security, slide 23	051 - Software Security::s23::1	0.23 LOW	supported
2	Because bounds are not checked, the excess data spills into adjacent higher stack memory, letting the attacker replace the return address and divert execution.	"By controlling buffer content, an attacker can overwrite the return address with an arbitrary value and hijack the execution flow."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.21 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 21; 051 - Software Security, slide 23

A4b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six Windows security mechanisms or components, identifying for each what it does within the Windows security architecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Security Reference Monitor in kernel mode performs ACL verification.	"Security Reference Monitor: ACL verification"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	0.50	supported (ste gate)
2	The winlogon log-on process handles user logon in user mode.	"Log-on process (winlogon): user logon"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	0.71	supported (ste gate)
3	The Local Security	"Local Security Authority (LSA):	041 - Windows	041 - Windows	0.82	supported (ste

	Authority verifies and changes passwords and manages access tokens and audit logs.	password verification and change, access tokens, audit logs"	Security, slide 3	Security::s03::1		gate)
4	The Security Accounts Manager holds the accounts database and performs password encryption.	"Security Accounts Manager (SAM): accounts database, password encryption"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	0.75	supported (ste gate)
5	User Account Control enforces limited user privileges.	"User Account Control (UAC, Vista): enforcement of limited user privileges"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	1.00	supported (ste gate)
6	Security credentials for a subject are kept in a token that maps principals to subjects and may carry extra security attributes.	"Security credentials for a subject are stored in a token."	041 - Windows Security, slide 11	041 - Windows Security::s11::1	0.36 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 3

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how spyware and adware differ in the harm they cause, identifying for each the security objective from the CIA triad that is affected.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Spyware harms confidentiality because it steals user logins and passwords and can compromise sensitive bank information.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.31 LOW	partly supporte
2	Adware is largely harmless and merely annoying, generating popup ads that interrupt other programs rather than breaching a security objective.	"Adware as such are quite harmless, although they are annoying. They generate ads in the form of popups and interrupt other programs"	051 - Software Security, slide 13	051 - Software Security::s13::1	0.56	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 13

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Based on the scenario in (a), justify how the Samy worm's use of cross-site scripting allowed it to spread automatically, giving six distinct points about its injection, propagation and impact.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by manipulating the document body.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.67	supported (ste gate)
2	It retrieved the victim's list of friends by issuing a GET request to a user	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.25 LOW	partly supporte

© Hak Cipta Universiti Teknologi MARA

	profile.					
3	It added Samy as a friend by performing an XML-HTTP request on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.78	supported (ste gate)
4	Any visitor to an infected profile had their own profile and friends list infected, enabling automatic onward spread.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.27 LOW	supported
5	The worm's scale of impact was very large, eventually infecting about one million profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.30 LOW	supported
6	The underlying weakness was that the web application returned user input without filtering, making it a potential XSS vulnerability.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.69	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the difference between morals, ethics and laws as three forms of guidance for conduct, giving the defining characteristic of each.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Morals are described as traditions of belief concerning right and wrong conduct, forming the basis of social behaviour.	"Morals are traditions of belief about right and wrong conduct"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.55	supported (ste gate)
2	Ethics is characterised as a set of guiding beliefs, standards or ideals that permeates an individual or a community.	"Ethics is a suite of guiding beliefs, standards, or ideals that pervades an individual or a group or community of people"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.70	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss how a professional code of ethics and conduct guides a computing professional's behaviour, referring to the ACM code and the professional bodies that maintain such codes. Support your discussion with six distinct points.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	State that professional bodies such as the ACM publish a formal	"Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct."	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1	0.50	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	code of ethics and professional conduct for their members.					
2	Explain that ethics is a documented set of acceptable behaviours defined by a professional or social group.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.67	supported (ste gate)
3	Note that the code identifies which specific actions are appropriate or inappropriate for the professional.	"Identifies specific actions as appropriate or inappropriate."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.50	supported (ste gate)
4	Describe the expectation that the professional avoids harm and remains honest and trustworthy in their work.	"Avoid harm. Be honest and trustworthy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.50	supported (ste gate)
5	Describe the expectation that the professional respects privacy and honours confidentiality of information.	"Respect privacy. Honor confidentiality."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.43 LOW	supported
6	Explain that the professional must keep up high standards of competence, conduct and ethical practice in their work.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.70	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12; 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 7

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) facts about the chain of trust in the Trusted Computing architecture, including how measurements are recorded and where the chain begins.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Each stage of the chain measures and validates the following stage.	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.60	supported (ste gate)
2	The measurements produced during the chain are stored in Platform Configuration Registers (PCRs) on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 8

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe the two primary system components of the Next Generation Secure Computing Base (NGSCB), explaining the role of each component and how they relate to one another.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Nexus is a special kernel forming the core of the trusted operating environment.	"Special kernel (core of the trusted operating)"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.62	supported (ste gate)
2	Nexus is a security kernel that is authenticated on boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.80	supported (ste gate)
3	Nexus authenticates trusted programs and provides the application interface to the TPM.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.38 LOW	partly supporte
4	Nexus does not trust the operating system.	"Does not trust OS"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.50	supported (ste gate)
5	The Nexus Computing Agent (NCA) is a trusted software component.	"Trusted software component"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.33 LOW	supported
6	The NCA runs in a trusted mode that communicates with Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) typical locations where network-based IDS sensors are placed in a network architecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Sensors are placed just inside the firewall.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.60	supported (ste gate)
2	Sensors are placed on the DMZ.	"On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.33 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 062 - Intrusion Detection System, slide 7

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Compare the preventive roles of a firewall and a remote access VPN in network security, and explain how an intrusion detection system complements these preventive mechanisms. Provide six distinct points.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A firewall is a preventive mechanism that controls incoming and outgoing network traffic according to predefined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.58	supported (ste gate)
2	A remote access VPN is a preventive mechanism that gives individual hosts or clients secure access to	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.73	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	an organization's network.					
3	An IDS monitors network resources to detect intrusions and attacks that preventive techniques such as firewalls and proxy servers failed to stop.	"Monitors network resources to detect intrusions and attacks that were not stopped by preventative techniques (firewalls, proxy servers, packet-filtering routers, network segmentations)"	062 - Intrusion Detection System, slide 3	062 - Intrusion Detection System::s03::1	0.80	supported (ste gate)
4	A proxy server acts as a firewall and web filter, so it is another preventive mechanism that improves data security and network performance.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.57	supported (ste gate)
5	Network segmentation creates boundaries between network segments whose assets share a common function, risk or role, thereby limiting exposure.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.60	supported (ste gate)
6	IDS/IPS detect or prevent attacks such as brute force attacks, denial-of-service attacks and exploits of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.85	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4; 062 - Intrusion Detection System, slide 3

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) advantages of having an organizational ethical code that clarify how technology professionals should behave.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	It makes acceptable standards of behaviour clearer to understand.	"Adds clarity to the understanding of acceptable standards of behavior."	071 - Ethics and Computer Security, slide 8	071 - Ethics and Computer Security::s08::1	0.50	supported (ste gate)
2	It spreads shared guidelines that everyone is expected to follow.	"Communicates common guidelines for everyone to follow."	071 - Ethics and Computer Security, slide 8	071 - Ethics and Computer Security::s08::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 8

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six responsibilities that information specialists and general users carry when handling data within ethical, moral and legal constraints, and explain why merely describing these moral and ethical dimensions of ICT is not sufficient for organizational privacy protection.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment

© Hak Cipta Universiti Teknologi MARA

1	Information specialists specifically are expected to act within ethical, moral and legal limits when doing their work.	"information specialists in particular, have definite responsibilities in terms of performing within ethical, moral, and legal constraints"	071 - Ethics and Computer Security, slide 3	071 - Ethics and Computer Security::s03::1	0.50	supported (ste gate)
2	Ordinary users, not only specialists, also bear definite responsibilities for staying within ethical, moral and legal constraints.	"Users in general, and information specialists in particular, have definite responsibilities"	071 - Ethics and Computer Security, slide 3	071 - Ethics and Computer Security::s03::1	0.27 LOW	supported
3	Simply describing the moral and ethical dimensions of ICT is not enough; organizations must go beyond description.	"Simply describing may not be enough when discussing the moral and ethical dimensions of ICT"	071 - Ethics and Computer Security, slide 3	071 - Ethics and Computer Security::s03::1	0.64	supported (ste gate)
4	Organizations must actively discuss the moral and ethical dimensions of ICT rather than only describing them.	"when discussing the moral and ethical dimensions of ICT"	071 - Ethics and Computer Security, slide 3	071 - Ethics and Computer Security::s03::1	0.36 LOW	partly supporte
5	A person who is separated from law and justice is described as the worst of all animals, showing the need for legal and just conduct.	"when separated from law and justice, he is the worst of all"	071 - Ethics and Computer Security, slide 4	071 - Ethics and Computer Security::s04::1	0.39 LOW	supported
6	A perfected person is the best of animals, implying that ethical development supports responsible behaviour.	"Man, when perfected, is the best of the animals"	071 - Ethics and Computer Security, slide 4	071 - Ethics and Computer Security::s04::1	0.30 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 3; 071 - Ethics and Computer Security, slide 4

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) password security controls that can be applied to protect password files and user accounts.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Apply access control to password files so that they are protected from unauthorised reading.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.44 LOW	partly supporte
2	De-activate user accounts after multiple failed login attempts.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 12

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how single sign-on reduces the burden of authentication for users, and describe how Kerberos and

© Hak Cipta Universiti Teknologi MARA

smart cards support authentication in distributed environments.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Single sign-on reduces the need for users to memorize multiple passwords.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.50	supported (ste gate)
2	Single sign-on reduces the time users spend typing passwords.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.43 LOW	supported
3	Single sign-on lowers the effort needed to maintain passwords.	"Reducing password maintenance effort"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.29 LOW	supported
4	Kerberos is a client-server architecture used to achieve single sign-on.	"Client-server architectures (Kerberos, Active Directory)"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.57	supported (ste gate)
5	In Kerberos login, the hash of the user's password becomes the user's secret key.	"The hash value of his password KU = h(P) becomes a secret key of the client/user."	022 - Identification and Authentication, slide 19	022 - Identification and Authentication::s19::1	0.71	supported (ste gate)
6	Smart cards are an alternative authentication mechanism to passwords and shared secrets.	"Alternative user authentication mechanisms are smart cards, biometric methods and two-factor authentication."	022 - Identification and Authentication, slide 24	022 - Identification and Authentication::s24::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 19; 022 - Identification and Authentication, slide 24

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss five ways in which intrusion detection and related defensive mechanisms can help detect and defend against malware attacks on the company's systems.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	An IDS can detect malicious activity occurring in computer systems.	"Detects malicious activity in computer systems"	062 - Intrusion Detection System, slide 2	062 - Intrusion Detection System::s02::1	0.62	supported (ste gate)
2	An IDS can identify and stop attacks that are currently in progress.	"Identifies and stops attacks in progress"	062 - Intrusion Detection System, slide 2	062 - Intrusion Detection System::s02::1	0.50	supported (ste gate)
3	A passive detection system can log and alert when an attack is identified.	"Can take passive action (logging and alerting) when an attack is identified"	062 - Intrusion Detection System, slide 29	062 - Intrusion Detection System::s29::1	0.75	supported (ste gate)
4	Misuse detection systems can recognise known bad behaviour by matching attack patterns or signatures.	"MDSs try to recognize known "bad" behavior."	062 - Intrusion Detection System, slide 17	062 - Intrusion Detection System::s17::1	0.17 LOW	partly supporte
5	Sandboxing provides a safe, isolated environment in which to run or open suspected insecure programs or	"A safe, protected and isolated environment in computer system to run or open suspected insecure programs or files."	061 - Network Security, slide 26	061 - Network Security::s26::1	0.82	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	files.					

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 061 - Network Security, slide 26; 062 - Intrusion Detection System, slide 17; 062 - Intrusion Detection System, slide 2; 062 - Intrusion Detection System, slide 29

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain five classes of threats to information systems and, for each class, identify the security service that counters it.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Disclosure is a threat class involving unauthorized access to information, and confidentiality services are the countermeasure.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.40 LOW	partly supporte
2	Deception is a threat class in which false data is accepted, and integrity services counter this threat.	"Deception - acceptance of false data"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.44 LOW	partly supporte
3	Disruption is a threat class that interrupts or prevents correct operation, and integrity services counter it.	"Disruption - interruption or prevention of correct operation"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.50	supported (ste gate)
4	Usurpation is a threat class involving unauthorized control of part of a system, and availability services counter it.	"Usurpation - unauthorized control of some part of a system"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.46 LOW	partly supporte
5	A threat is a potential violation of security, whereas an attack is the actual violation of security.	"Threats: A threat is a "potential" violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.57	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 011 - Introduction to Computer Security, slide 10; 011 - Introduction to Computer Security, slide 9

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State the four goals of access control and explain the role of a reference monitor in authorization. Then describe how the Chinese Wall policy constrains a consultant's access to company information, and explain why this policy is described as history-sensitive.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	List the four access control goals: granting, limiting, preventing and revoking access.	"Goals of access control: Granting access Limiting access Preventing access Revoking access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	1.00	supported (ste gate)
2	State that the reference monitor is the component that makes	"Reference monitor makes authorization decisions."	023 - Access Control and Authorization,	023 - Access Control and Authorization::s04::1	1.00	supported (ste gate)

	authorization decisions.		slide 4			
3	Explain that reference monitors realize access control policies and can be placed at every level of the system hierarchy.	"Reference monitors are instruments for realization of access control policies. They can be deployed at all levels of system hierarchy."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1	0.83	supported (ste gate)
4	Describe the simple Chinese Wall rule: a subject may read a company's information only if it has not already accessed information from another company in the same conflict class.	"A subject may access information from any company as long as that subject has never accessed information from a different company in the same conflict class."	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.50	supported (ste gate)
5	Explain that permissions under the Chinese Wall change dynamically because the rights a subject holds depend on its history of past accesses.	"Notice that permissions change dynamically. The access rights that any subject enjoys depends on the history of past accesses"	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.64	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 4; 024 - Formal Security Model, slide 24

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the Chinese Wall policy as a formal security model, covering the two rules that govern read and write access, the type of policy it is classified as, and the specific problem it was designed to solve.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The simple security rule permits a subject to access an object only when the object is either in the same company dataset as objects the subject has already accessed (i.e., within the Wall) or in a completely different conflict of interest class.	"is in the same company datasets as the objects already accessed by s, that is, "within the Wall," or belongs to an entirely different conflict of interest class."	024 - Formal Security Model, slide 25	024 - Formal Security Model::s25::1	0.52	supported (ste gate)
2	The Chinese Wall *-property allows a write only if the simple security rule permits the access and the subject cannot read any unsanitized object belonging to a different company dataset than the one being written to.	"(Chinese Wall) *-property: Write access is only permitted if: access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information."	024 - Formal Security Model, slide 26	024 - Formal Security Model::s26::1	0.73	supported (ste gate)
3	Strictly speaking the Chinese Wall is not an integrity policy but an access control confidentiality policy.	"Strictly speaking, this is not an integrity policy, but an access control confidentiality policy."	024 - Formal Security Model, slide 21	024 - Formal Security Model::s21::1	0.82	supported (ste gate)
4	The policy was designed by Brewer and Nash to address a very specific concern, namely conflicts of interest faced by a consultant or contractor.	"Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor."	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.92	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

5	The model illustrates that security policies can be crafted to solve very specialized problems.	"This illustrates that security policies can be crafted to solve"	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26; 024 - Formal Security Model, slide 27

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA